

[←](#) Go to **ACL ARR 2025 May** homepage (/group?id=aclweb.org/ACL/ARR/2025/May)

2 Versions ▾

From Capabilities to Performance: Evaluating Key Functional Properties of LLM Architectures in Penetration Testing

 (/pdf?
id=w4ncdtSynB)

Lanxiao Huang (/profile?id=~Lanxiao_Huang2),
Daksh Dave (/profile?id=~Daksh_Dave1), Tyler Cody (/profile?id=~Tyler_Cody1),
Peter A. Beling (/profile?id=~Peter_A._Beling2), Ming Jin (/profile?id=~Ming_Jin2)



 19 May 2025 (modified: 11 Mar 2026)  ACL ARR 2025 May Submission

 May, Senior Area Chairs, Area Chairs, Reviewers, Authors  Revisions (/revisions?id=w4ncdtSynB)

 CC BY 4.0 (<https://creativecommons.org/licenses/by/4.0/>)

Abstract:

Large Language Models (LLMs) have been explored for automating or enhancing penetration testing tasks, but their effectiveness and reliability across diverse attack phases remain open questions. This study presents a comprehensive evaluation of multiple LLM-based agents—from singular to modular—across realistic penetration testing scenarios, analyzing their empirical performance and recurring failure patterns. We further investigate the impact of core functional capabilities on agent success, operationalized through five targeted augmentations: Global Context Memory (GCM), Inter-Agent Messaging (IAM), Context-Conditioned Invocation (CCI), Adaptive Planning (AP), and Real-Time Monitoring (RTM). These interventions respectively support the capabilities of Context Coherence & Retention, Inter-Component Coordination & State Management, Tool Usage Accuracy & Selective Execution, Multi-Step Strategic Planning & Error Detection & Recovery, and Real-Time Dynamic Responsiveness. Our findings reveal that while some architectures natively exhibit select properties, targeted augmentations significantly enhance modular agent performance—particularly in complex, multi-step, and real-time penetration testing scenarios.

Paper Type: Long

Research Area: Speech Recognition, Text-to-Speech and Spoken Language Understanding

Research Area Keywords: red teaming, code generation and understanding, robustness, security/privacy, applications,

Contribution Types: Model analysis & interpretability, NLP engineering experiment, Data analysis, Position papers, Surveys

Languages Studied: Bash/Shell Scripting, PowerShell, Python, English

Previous URL: /forum?id=ul6vCdjdwy (/forum?id=ul6vCdjdwy)

Explanation Of Revisions PDF:  pdf (/attachment?id=w4ncdtSynB&name=explanation_of_revisions_PDF)

Reassignment Request Area Chair: No, I want the same area chair from our previous submission (subject to their availability).

Reassignment Request Reviewers: No, I want the same set of reviewers from our previous submission (subject to their availability)

A1 Limitations Section: This paper has a limitations section.

A2 Potential Risks: N/A

B Use Or Create Scientific Artifacts: No

B1 Cite Creators Of Artifacts: N/A

B2 Discuss The License For Artifacts: N/A

B3 Artifact Use Consistent With Intended Use: N/A

B4 Data Contains Personally Identifying Info Or Offensive Content: N/A

B5 Documentation Of Artifacts: N/A
B6 Statistics For Data: N/A
C Computational Experiments: No
C1 Model Size And Budget: N/A
C2 Experimental Setup And Hyperparameters: Yes
C2 Elaboration: Section 4.1, Appendix F
C3 Descriptive Statistics: N/A
C4 Parameters For Packages: N/A
D Human Subjects Including Annotators: No
D1 Instructions Given To Participants: N/A
D2 Recruitment And Payment: N/A
D3 Data Consent: N/A
D4 Ethics Review Board Approval: N/A
D5 Characteristics Of Annotators: N/A
E Ai Assistants In Research Or Writing: No
E1 Information About Use Of Ai Assistants: N/A
Author Submission Checklist: yes
Preprint: no
Preprint Status: There is no non-anonymous preprint and we do not intend to release one. (this option is binding)
Preferred Venue: ACL
Consent To Share Data: yes
Consent To Share Submission Details: On behalf of all authors, we agree to the terms above to share our submission details.
Association For Computational Linguistics - Blind Submission License Agreement: On behalf of all authors, I agree
Submission Number: 4801

Discussion (?id=w4ncdtSynB#discussion)

Filter by reply type...

Filter by author...

Search keywords...

Sort: Newest First

-

=

Everyone

Submission4801...

Submission4801...

Submission4801 Area...

Submission4801 Authors

Submission4801...

Program Chairs

Submission4801...

Submission4801...

Submission4801...

Submission4801...

10 / 10 replies shown

Add:

Author-Editor Confidential Comment

Withdrawal

Meta Review of Submission4801 by Area Chair zgCU

Meta Review

by Area Chair zgCU

16 Jul 2025, 06:06 (modified: 13 Aug 2025, 11:26)

Commitment Readers, Senior Area Chairs, Area Chairs, Authors, Reviewers Submitted, Program Chairs

Revisions (/revisions?id=gZRNWzxPi9)

Metareview:

This paper presents a comprehensive evaluation of LLM-based agents for penetration testing, investigating their performance across realistic scenarios and identifying key failure patterns. The study systematically analyzes the impact of five functional capabilities (context coherence, coordination, tool usage, planning, and responsiveness) and proposes targeted augmentations to enhance modular agent performance. While the work primarily builds on existing architectures and MAS principles, it provides valuable empirical insights and practical design guidance for deploying LLMs in cybersecurity tasks.

Summary Of Reasons To Publish:

The paper's strengths lie in its rigorous evaluation framework, which aligns with industry-standard cybersecurity frameworks (MITRE ATT&CK, NIST) and systematically links LLM failures to root causes. The proposed functional capability framework offers a generalizable foundation for future research, and the targeted augmentations demonstrate clear improvements in complex scenarios. The authors have addressed concerns about realism by emphasizing the framework's applicability to enterprise workflows and clarifying LLM versions.

Summary Of Suggested Revisions:

The main limitations include the lack of architectural novelty, as the augmentations apply existing MAS concepts rather than introducing new mechanisms. The testbed, while representative, may not fully capture large-scale enterprise environments, and reproducibility is hindered by underspecified parameters and unavailable datasets/software. Some reviewers noted that the failure mode analysis remains descriptive rather than deeply analyzing token-level or prompt-alignment issues. The software release is also limited, which may affect practical adoption.

The authors should strive to implement the improvements mentioned in the rebuttal in the revision.

Overall Assessment: 3.5 = Borderline Conference

Reported Issues:  No

Add: **Author-Editor Confidential Comment**

Official Comment by Area Chair zgCU

Official Comment by Area Chair zgCU  01 Jul 2025, 12:55 (modified: 04 Aug 2025, 17:17)

 Program Chairs, Reviewer K8mr, Reviewer KDFx, Reviewer qUoA, Senior Area Chairs, Area Chairs, Reviewers, Reviewers Submitted, Authors, Commitment Readers

 Revisions (/revisions?id=MSv0RbIJ30)

Comment:

We sincerely appreciate the reviewers' detailed and insightful comments, as well as the authors' comprehensive response.

Given the substantial new content provided in the authors' rebuttal, we encourage the reviewers to further engage with their replies. This additional discussion will help refine the manuscript by generating more actionable feedback and constructive ideas.

Add: **Author-Editor Confidential Comment**

Official Review of Submission4801 by Reviewer K8mr

Official Review by Reviewer K8mr  19 Jun 2025, 03:47 (modified: 04 Aug 2025, 17:17)

 Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer K8mr, Commitment Readers

 Revisions (/revisions?id=n7buQfh6i3)

Paper Summary:

This paper provides a comprehensive investigation into the application of Large Language Models (LLMs) in penetration testing. The study explores the roles LLMs can play in offensive security, evaluates their empirical performance in realistic benchmarking environments, identifies common failure modes, and compares single-agent and modular architectures.

Summary Of Strengths:

1. The study proposes four clearly defined research questions (RQ1-RQ4) that comprehensively address LLM's role positioning, empirical performance, failure modes, and architectural design in penetration testing, forming a complete research closed-loop.
2. Experimental tasks are designed based on the MITRE ATT&CK and NIST frameworks, ensuring alignment with industry standards and enhancing the practical relevance of the evaluation results.

3. The functional roles of LLM are systematically categorized into "autonomous attacker," "augmented assistant," and "hybrid model," establishing a clear theoretical framework for future research. This classification provides critical insights into the dual-use nature (offensive/defensive) of LLMs in cybersecurity contexts.

Summary Of Weaknesses:

- 1. The selected Research Area: Speech Recognition, Text-to-Speech and Spoken Language Understanding does not match the topic of this work.
- 2. The testing environment of the paper is primarily based on platforms such as Hack The Box and Metasploitable, which may not fully represent large-scale or more advanced enterprise networks. Future research could consider conducting tests in more complex network environments.

Comments Suggestions And Typos:

The version of LLMs, such as Claude, Gemini should be cleared.

Confidence: 4 = Quite sure. I tried to check the important points carefully. It's unlikely, though conceivable, that I missed something that should affect my ratings.

Soundness: 4 = Strong: This study provides sufficient support for all of its claims. Some extra experiments could be nice, but not essential.

Excitement: 3 = Interesting: I might mention some points of this paper to others and/or attend its presentation in a conference if there's time.

Overall Assessment: 3.5 = Borderline Conference

Ethical Concerns:

There are no concerns with this submission

Needs Ethics Review: No

Reproducibility: 3 = They could reproduce the results with some difficulty. The settings of parameters are underspecified or subjectively determined, and/or the training/evaluation data are not widely available.

Datasets: 1 = No usable datasets submitted.

Software: 3 = Potentially useful: Someone might find the new software useful for their work.

Knowledge Of Or Educated Guess At Author Identity: No

Knowledge Of Paper: N/A, I do not know anything about the paper from outside sources

Knowledge Of Paper Source: N/A, I do not know anything about the paper from outside sources

Impact Of Knowledge Of Paper: N/A, I do not know anything about the paper from outside sources

Reviewer Certification: I certify that the review I entered accurately reflects my assessment of the work. If you used any type of automated tool to help you craft your review, I hereby certify that its use was restricted to improving grammar and style, and the substance of the review is either my own work or the work of an acknowledged secondary reviewer.

Add:

Author-Editor Confidential Comment



Follow Up

Official Comment

by Authors (👁 Peter A. Beling (/profile?id=~Peter_A._Beling2), Lanxiao Huang (/profile?id=~Lanxiao_Huang2), Tyler Cody (/profile?id=~Tyler_Cody1), Ming Jin (/profile?id=~Ming_Jin2), +1 more (/group/edit?id=aclweb.org/ACL/ARR/2025/May/Submission4801/Authors))

👁 Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer K8mr, Commitment Readers

📄 Revisions (/revisions?id=a8pDX8eSEK)

Comment:

With the rebuttal period coming to a close, we sincerely hope that our responses and additional results have addressed your concerns. Please feel free to let us know if there is anything further we can clarify. And we would greatly appreciate it if you could consider updating your score in light of our clarifications.Thank you again for your valuable time and thoughtful feedback!

Add:

Author-Editor Confidential Comment



Responses & Additional Results

Official Comment

by Authors (👁 Peter A. Beling (/profile?id=~Peter_A._Beling2), Lanxiao Huang (/profile?id=~Lanxiao_Huang2), Tyler Cody (/profile?id=~Tyler_Cody1), Ming Jin (/profile?id=~Ming_Jin2), +1 more (/group/edit?id=aclweb.org/ACL/ARR/2025/May/Submission4801/Authors))

📅 29 Jun 2025, 17:57 (modified: 04 Aug 2025, 17:17)

👁 Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer K8mr, Commitment Readers

📄 Revisions (/revisions?id=jL3RJ8DnFc)

Comment:

We sincerely thank Reviewer K8mr for the thoughtful and constructive feedback. Below we address each point in detail.

W1. Research Area Classification

We acknowledge that the originally selected Research Area (*Speech Recognition, Text-to-Speech and Spoken Language Understanding*) was an oversight. Our work is more accurately aligned with **NLP Applications**, as it systematically evaluates LLMs in penetration testing scenarios and offensive security tasks. We will correct this in the final metadata to better reflect the paper’s true scope and contribution.

W2. Realism of the Benchmarking Environment

We agree that our current testbed (Hack The Box and Metasploitable) represents controlled lab-scale environments. To mitigate this, our task design explicitly maps each evaluation step to real-world adversarial techniques using the MITRE ATT&CK and NIST frameworks (see Sections 4 and Appendix D). This mapping ensures that key functional properties — such as multi-step planning, context retention, and real-time responsiveness — are stressed under conditions that reflect enterprise-level adversarial workflows.

Additionally, we would like to clarify that our testbed is comparable to those used in closely related works, such as PentestGPT, AutoAttacker, PenHeal and Cybench, which also rely on CTF-style or vulnerability-focused platforms like HTB and VulnHub. These environments are widely accepted as representative baselines for agent-based penetration testing research because they provide reproducible, well-scoped targets that can be mapped to industry frameworks.

Our findings highlight failure modes and performance drop-offs that stem from fundamental architectural gaps, not just environment-specific quirks. These insights generalize to more complex infrastructures and motivate future extensions. We will emphasize this generalizability more clearly in the final version and also note that future work will expand testing to larger-scale, hybrid enterprise testbeds.

Comments: Clarification of LLM Versions

We appreciate this suggestion. We would like to clarify that the specific versions and configurations for each LLM used — such as GPT-4, Claude 3.5 Sonnet, Gemini 2.0 Flash, etc. — are already documented in **Appendix F.2** along with consistent generation hyperparameters for reproducibility. We confirm that no additional fine-tuning or external memory augmentation was applied, beyond any native retrieval mechanisms where stated. In the final version, we will add an explicit reference in the main text to direct readers to this appendix section for transparency.

Additional Experiments on Failure Mode Evidence

We also wish to note that, in response to Reviewer KDFx’s suggestion, we have added a new FM–FR–Root cause table that quantifies the mapping between high-level failure modes, specific empirical failure reasons, and their deeper root causes, with occurrence rates derived from our logs. This table, along with

prompt-output trace examples, will appear in the Appendix. We believe this additional evidence strengthens our overall empirical analysis and will benefit all readers by clarifying how our proposed modular augmentations directly target the practical origins of each failure channel.

Add: **Author-Editor Confidential Comment**

Official Review of Submission4801 by Reviewer KDFx

Official Review by Reviewer KDFx 📅 19 Jun 2025, 01:41 (modified: 04 Aug 2025, 17:17)

👁 Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer KDFx, Commitment Readers

📄 Revisions (/revisions?id=oRU5mQA8t)

Paper Summary:

This paper presents a comprehensive evaluation of LLM-based agents, ranging from monolithic models like GPT-4 and Claude to modular systems such as PentestGPT, AutoAttacker, and PenHeal, for realistic penetration testing tasks. The authors assess these agents across various PT phases (e.g., reconnaissance, exploitation, post-exploitation), using standardized frameworks like MITRE ATT&CK and NIST SP 800-115. Central to the study is the identification of five key functional capabilities, context coherence, coordination, tool usage accuracy, strategic planning, and real-time responsiveness, each mapped to a targeted augmentation (e.g., GCM, IAM, CCI, AP, RTM). The findings demonstrate that while single-agent models show strengths in simple tasks, modular agents benefit greatly from these interventions in complex, multi-step scenarios. Notably, all models struggle with real-time tasks such as MITM attacks. The paper contributes a principled analysis of LLM failure modes and demonstrates how MAS-inspired augmentations can meaningfully enhance reliability, highlighting the functional prerequisites for robust autonomous security agents.

Summary Of Strengths:

1. The paper systematically evaluates LLMs across a wide range of penetration testing tasks aligned with established cybersecurity frameworks (MITRE ATT&CK, NIST SP 800-115), lending practical relevance to the study.
2. Mapping performance to concrete functional capabilities (e.g., context retention, real-time responsiveness) is conceptually valuable and helps the paper generalize beyond specific model architectures. This provides a principled lens that can extend to other domains.
3. The paper goes beyond performance metrics to conduct an in-depth analysis of failure modes (e.g., hallucinations, looping, tool misuse), which is essential for understanding and improving model reliability.

Summary Of Weaknesses:

1. ACL values conceptual or methodological innovation. Since the paper primarily evaluates existing agents and applies known MAS concepts (e.g., planning, memory modules) as modular augmentations, it lacks a clear architectural or algorithmic novelty.
2. Without a new learning paradigm or architectural mechanism, the contribution may be viewed as more empirical than scientific, which weakens its core claim unless very strong generalization or insights are demonstrated.
3. The paper catalogs failure modes (hallucinations, looping) well but does not deeply analyze their internal origins (e.g., token-level errors, prompt misalignment).

Comments Suggestions And Typos:

1. The paper focuses on evaluating existing architectures and applying MAS-inspired augmentations, which, while useful, may not meet the novelty bar.
2. While failure modes are well-documented (e.g., hallucinations, looping), the analysis remains descriptive.
3. The authors may consider adopting or exploring a graph-based workflow representation to model penetration testing processes and LLM-agent interactions.
4. A graph-based formulation could facilitate better planning, loop detection, and context retention, especially in modular agent setups.

Confidence: 3 = Pretty sure, but there's a chance I missed something. Although I have a good feel for this area in general, I did not carefully check the paper's details, e.g., the math or experimental design.

Soundness: 3 = Acceptable: This study provides sufficient support for its main claims. Some minor points may need extra support or details.

Excitement: 2.5

Overall Assessment: 3.5 = Borderline Conference

Ethical Concerns:

There are no concerns with this submission

Needs Ethics Review: No

Reproducibility: 3 = They could reproduce the results with some difficulty. The settings of parameters are underspecified or subjectively determined, and/or the training/evaluation data are not widely available.

Datasets: 1 = No usable datasets submitted.

Software: 1 = No usable software released.

Knowledge Of Or Educated Guess At Author Identity: No

Knowledge Of Paper: N/A, I do not know anything about the paper from outside sources

Knowledge Of Paper Source: N/A, I do not know anything about the paper from outside sources

Impact Of Knowledge Of Paper: Not much

Reviewer Certification: I certify that the review I entered accurately reflects my assessment of the work. If you used any type of automated tool to help you craft your review, I hereby certify that its use was restricted to improving grammar and style, and the substance of the review is either my own work or the work of an acknowledged secondary reviewer.

Add:

Author-Editor Confidential Comment



Responses & Additional Results

Official Comment

by Authors (👁 Peter A. Beling (/profile?id=~Peter_A._Beling2), Lanxiao Huang (/profile?id=~Lanxiao_Huang2), Tyler Cody (/profile?id=~Tyler_Cody1), Ming Jin (/profile?id=~Ming_Jin2), +1 more (/group/edit?id=aclweb.org/ACL/ARR/2025/May/Submission4801/Authors))

📅 29 Jun 2025, 18:00 (modified: 04 Aug 2025, 17:17)

👁 Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer KDFx, Commitment Readers

📄 Revisions (/revisions?id=OkBQq63ABW)

Comment:

We thank Reviewer KDFx for the thoughtful assessment and detailed suggestions. Below we address each key weakness point by point.

W3: In the current version, Table 5 and Section 5 link empirical failure reasons to broader Failure Modes. To address the concern about tracing internal origins, we will add the following FM-FR-Root table with occurrence rates calculated based on our experiment logs, clarifying a clear mapping for each deeper cause. The final table will appear in the Appendix along with short prompt-output trace examples for each FM, improving the descriptive analysis with a more formal structure as concerned in C2. We will also emphasize that our modular augmentations target these root failure channels: GCM mitigates context loss, IAM improves inter-agent memory and reduces exposure bias loops, CCI constrains prompt drift, and RTM conducts runtime checks.

Failure Modes (FMs)	Failure Reasons (FRs)	Root Causes & Short Definitions	Occurrence %
FM1: Hallucination and Syntax Errors	Syntax Errors; Tool Misinterpretation; Command Execution Errors	Prompt ambiguity: missing/unclear instructions	57%
		Token-level drift: local generation deviation	30%
		Sampling randomness: decoding variability	13%

Failure Modes (FMs)	Failure Reasons (FRs)	Root Causes & Short Definitions	Occurrence %
FM2: Looping and Repetition	Stuck in Loop; Premature Termination (loop-induced)	Prompt chain misalignment: no stop condition	68%
		Missing inter-agent state: agents fail to share memory	22%
		Exposure bias: safe step repeats	10%
FM3: Tool and Task Coverage Gaps	Correct Brute-Force Ignored; Ignored Hints for MRO; Lack of Contextual Understanding; Access Denied; API Rate Limiting Issues; Dependency Conflicts; Difficulty with AD/Priv Esc	Context window limits & overshadowing: buried info in long prompts	50%
		Knowledge gaps: rare tool facts poorly retained	8%
		Alignment bias: "always answer" tendency	30%
		Missing runtime hooks: no environment verification	12%

Some of the key references:

- Huang, Lei, et al. "A survey on hallucination in large language models: Principles, taxonomy, challenges, and open questions."
- Liu, Nelson F., et al. "Lost in the middle: How language models use long contexts."
- Yao, Shunyu, et al. "React: Synergizing reasoning and acting in language models."

W1: We agree our modular augmentations apply known MAS principles rather than proposing a novel LLM architecture. Our contribution is to systematically map these well-known generation failure roots to concrete multi-agent operational failures unique to realistic penetration testing workflows. By quantifying these links (see FM–FR–Root table) and showing how each module directly targets specific failure channels, we offer practical design guidance new for deployable LLM security agents. We will clarify this empirical systems focus in our framing.

W2: We acknowledge we do not introduce a new training or finetuning paradigm. Instead, our work reflects a growing trend in cybersecurity: using general-purpose LLMs as agent cores, relying on strong zero/few-shot capability rather than domain-specific finetuning. Our results show how runtime modularity and tool-aware orchestration mitigate these roots without changing the base model. We will clarify that this reusable, evidence-based benchmark fills a gap for trustworthy LLM deployment in high-stakes red teaming.

Graph-based representation: We clarify that figures 1 and 7 already show our evaluation workflow and LLM-augmented PT lifecycle. But we will add a more concise graph-based representation to illustrate how our proposed modular augmentations strengthen edges, close loops, and mitigate failure propagation in final version.

Add:

Author-Editor Confidential Comment



Reviewer Response

Official Comment by Reviewer KDFx 01 Jul 2025, 10:52 (modified: 04 Aug 2025, 17:17)

Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer KDFx, Commitment Readers

Revisions (/revisions?id=5ljn08FfuR)

Comment:

Dear authors,

Thank you for your response. I modified my rate : 3 -> 3.5

Add: **Author-Editor Confidential Comment**

Official Review of Submission4801 by Reviewer qUoA

Official Review by Reviewer qUoA 16 Jun 2025, 06:41 (modified: 04 Aug 2025, 17:17)

Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer qUoA, Commitment Readers

Revisions (/revisions?id=V2QfLgSPfC)

Paper Summary:

This study evaluates Large Language Models (LLMs) for automating penetration testing, finding that while they offer flexibility, their effectiveness and reliability remain open questions, especially in complex scenarios. All models demonstrated significant limitations in real-time dynamic responsiveness, uniformly failing on Man-in-the-Middle (MITM) attacks and showing performance drops in multi-step tasks like post-exploitation. Primary failure modes observed include hallucinated commands, syntax errors, redundant looping, and context fragmentation. The research introduces five targeted augmentations—Global Context Memory (GCM), Inter-Agent Messaging (IAM), Context-Conditioned Invocation (CCI), Adaptive Planning (AP), and Real-Time Monitoring (RTM)—to address these shortcomings.

Summary Of Strengths:

Large Language Models (LLMs) offer a flexible paradigm for cybersecurity, capable of reasoning through attack paths, generating payloads, and dynamically responding to network feedback, which enhances or automates penetration testing tasks. They demonstrate strong potential as autonomous attackers in core penetration testing tasks like reconnaissance and credential exploitation, able to discover vulnerabilities and craft exploits with minimal human oversight. LLMs also excel as augmented assistants, supporting human penetration testers by recommending commands, optimizing workflows, and generating valuable code snippets or strategic suggestions.

Summary Of Weaknesses:

The effectiveness and reliability of Large Language Models (LLMs) across diverse attack phases remain open questions. Many models demonstrated tool misinterpretation and insufficient adaptation to complex scenarios, often requiring frequent human intervention and guidance for successful task completion.

I'm sorry, but I'm not a specialist in this field, so I can't tell you anything more about this article.

Comments Suggestions And Typos:

No comments.

Confidence: 1 = Not my area, or paper is very hard to understand. My evaluation is just an educated guess.

Soundness: 3.5

Excitement: 3.5

Overall Assessment: 3.5 = Borderline Conference

Ethical Concerns:

There are no concerns with this submission

Needs Ethics Review: No

Reproducibility: 2 = They would be hard pressed to reproduce the results: The contribution depends on data that are simply not available outside the author's institution or consortium and/or not enough details are provided.

Datasets: 1 = No usable datasets submitted.

Software: 3 = Potentially useful: Someone might find the new software useful for their work.

Knowledge Of Or Educated Guess At Author Identity: No

Knowledge Of Paper: N/A, I do not know anything about the paper from outside sources

Knowledge Of Paper Source: N/A, I do not know anything about the paper from outside sources

Impact Of Knowledge Of Paper: N/A, I do not know anything about the paper from outside sources

Reviewer Certification: I certify that the review I entered accurately reflects my assessment of the work. If you used any type of automated tool to help you craft your review, I hereby certify that its use was restricted to improving grammar and style, and the substance of the review is either my own work or the work of an acknowledged secondary reviewer.

Add:

Author-Editor Confidential Comment



Responses & Additional Results

Official Comment

by Authors (👁 Peter A. Beling (/profile?id=~Peter_A._Beling2), Lanxiao Huang (/profile?id=~Lanxiao_Huang2), Tyler Cody (/profile?id=~Tyler_Cody1), Ming Jin (/profile?id=~Ming_Jin2), +1 more (/group/edit?id=aclweb.org/ACL/ARR/2025/May/Submission4801/Authors))

📅 29 Jun 2025, 18:09 (modified: 04 Aug 2025, 17:17)

👁 Program Chairs, Senior Area Chairs, Area Chairs, Reviewers Submitted, Authors, Reviewer qUoA, Commitment Readers

📄 Revisions (/revisions?id=n53dqYGFwj)

Comment:

We sincerely thank Reviewer qUoA for reading our paper and providing an evaluation, despite acknowledging that penetration testing with LLM agents is not within their direct area of specialization. We appreciate your recognition that our study demonstrates the flexible roles LLMs can play in cybersecurity and highlights important limitations such as real-time responsiveness and multi-step task adaptation.

We would like to take this opportunity to clarify how our study extends beyond a narrow empirical assessment to contribute broadly generalizable insights for the NLP and security communities:

Effectiveness and Reliability Across Diverse Phases

We agree that the overall effectiveness and reliability of LLMs in realistic penetration testing remains an open challenge—especially as tasks grow more complex and dynamic. Our key contribution is to show that success depends less on whether an agent is single or modular, and more on whether it embodies core *functional properties* such as long-range context retention, strategic planning, real-time responsiveness, and tool usage accuracy. As Section 4 and Figure 2 show, our results systematically quantify how these properties impact subtask completion rates across all phases, from reconnaissance to complex multi-step exploitation and post-exploitation.

Tool Misinterpretation and Need for Human Oversight

You noted that models often misinterpret tools or fail to adapt in complex scenarios, which then requires frequent human intervention to recover. Our failure mode analysis (Section 5 and Table 5) shows how syntax errors, redundant looping, and tool misuse are closely tied to missing inter-component coordination or runtime checks. To address this, we introduce targeted augmentations such as *Context-Conditioned Invocation (CCI)* to prevent redundant or incorrect tool calls, and *Adaptive Planning (AP)* to improve recovery from partial failures.

Figures 5 and 6 (Risk-Task Matrix and Donut Chart) further demonstrate how the degree of required human oversight directly correlates with task complexity and risk—highlighting that agents lacking these properties demand substantially more human guidance to complete high-risk tasks like multi-stage privilege escalation or real-time MITM attacks.

Root Cause Evidence for Better Generalization

In response to related comments by Reviewer KDFx, we have also added an extended experiment mapping these empirical failure reasons back to their root causes (e.g., prompt ambiguity, missing runtime hooks). This FM-FR-Root table will appear in the Appendix. By providing this additional evidence, we show that the same functional properties we test can systematically mitigate these weaknesses—offering practical design guidance for improving LLM effectiveness and reliability in other real-world scenarios.

Broad Relevance of Functional Properties

The core contribution of our work lies not only in benchmarking LLMs for penetration testing, but in systematically mapping observed performance and failure modes to five functional properties (e.g., Context Coherence & Retention, Real-Time Responsiveness) and showing how these capabilities can be operationalized via targeted augmentations (GCM, IAM, CCI, AP, RTM). While our testbed is in offensive security, the properties and augmentation principles are general to other complex, multi-phase NLP tasks that involve long context, tool usage, or dynamic environment feedback. This helps bridge the gap between practical empirical findings and broader architectural design guidance for robust LLM deployment.

We hope this clarifies how our contribution goes beyond a static benchmark by offering actionable evidence, OpenReview.net Support, and a functional framework that generalizes to foundation agent design. We are grateful for your thoughtful comments and your open reflection on domain expertise.

Sponsors (/sponsors)

Add:

Author Terms of Use (/legal/terms)Feedback (/legal/feedback)Privacy Policy (/legal/privacy)

News (/group?id=OpenReview.net/News&referrer=

Privacy Policy (/legal/privacy)

[Homepage](/))

OpenReview (/about) is a long-term project to advance science through improved peer review with legal nonprofit status. We gratefully acknowledge the support of the OpenReview Sponsors (/sponsors). © 2026 OpenReview